

Trường Đại Học FPT - Hà Nội

Khoa: An Toàn Thông Tin

-----o0o-----



BÁO CÁO DỰ ÁN MÔN HỌC

IAA202

Đề Tài

SmartEMS - Smart Employee Management Solution

GIẢNG VIÊN: NGUYỄN THANH TUẤN

LỚP: IA2001

NHÓM: 4

THÀNH VIÊN:

Nguyễn Công Doanh - HE190277

Nguyễn Trung Anh - HE190843

Phan Văn Hiếu - HE190773

Hoàng Ngọc Năng - HE194331

HÀ NỘI, NGÀY 10 THÁNG 7 NĂM 2026

MỤC LỤC

PHẦN 1. TÓM TẮT TỔNG QUAN VÀ BỐI CẢNH VẤN ĐỀ

- 1.1. Giới thiệu doanh nghiệp mô phỏng
- 1.2. Mục tiêu của Khung Quản lý Rủi ro (RMF)

PHẦN 2. PHÂN TÍCH RỦI RO TOÀN DIỆN

- 2.1 Quy trình đánh giá rủi ro (Risk Assessment Process)
- 2.2 Xác định tài sản (Asset Identification)
- 2.3. Xác định Mối đe dọa & Lỗ hổng (Threat & Vulnerability Identification)
- 2.4. Phân tích và Đánh giá Rủi ro (Risk Assessment)

PHẦN 3. ĐỀ XUẤT CHIẾN LƯỢC GIẢM THIỂU RỦI RO

- 3.1. Phân tích Chi phí – Lợi ích
- 3.2. Các Biện pháp Kiểm soát Đề xuất
- 3.3. Ảnh xạ với Chuẩn Quốc tế

PHẦN 4. ỨNG PHÓ VÀ KHÔI PHỤC

- 4.1. Business Impact Analysis (BIA)
- 4.2. Business Continuity Plan (BCP)
- 4.3. Disaster Recovery Plan (DRP)
- 4.4. Computer Incident Response Team (CIRT)
- 4.5. Kết luận

PHẦN 5. AI USAGE REFLECTION

5.1. Bảng tổng hợp việc sử dụng AI

5.2. Đánh giá và giới hạn của AI

PHẦN 6: TÀI LIỆU THAM KHẢO

PHẦN 1: TÓM TẮT TỔNG QUAN & BỐI CẢNH VẤN ĐỀ

1.1. Giới thiệu về Doanh nghiệp mô phỏng

a. Giới thiệu doanh nghiệp mô phỏng

Để phục vụ cho quá trình đánh giá an toàn thông tin, nhóm xây dựng một doanh nghiệp mô phỏng mang tên **SmartEMS**. Doanh nghiệp được xây dựng với mục đích mô phỏng một môi trường làm việc thực tế, nơi các hoạt động quản lý nhân sự được thực hiện thông qua một hệ thống quản lý tập trung. Việc xây dựng doanh nghiệp mô phỏng giúp quá trình đánh giá rủi ro, phân tích lỗ hổng bảo mật và đề xuất các biện pháp bảo vệ được thực hiện trong điều kiện gần với môi trường doanh nghiệp thực tế, đồng thời tạo cơ sở để áp dụng Khung Quản lý Rủi ro (Risk Management Framework – RMF) vào quá trình đánh giá hệ thống.

b. Giới thiệu hệ thống SmartEMS

SmartEMS triển khai hệ thống **SmartEMS (Smart Employee Management System)** nhằm hỗ trợ quản lý nhân sự trong doanh nghiệp. Hệ thống được phát triển dưới dạng website, cho phép người dùng truy cập thông qua trình duyệt web để thực hiện các nghiệp vụ quản lý mà không cần cài đặt phần mềm trên máy tính. Việc áp dụng hệ thống giúp doanh nghiệp số hóa các quy trình quản lý nhân sự, giảm thiểu việc sử dụng giấy tờ và các thao tác thủ công, từ đó nâng cao hiệu quả quản lý, tiết kiệm thời gian xử lý công việc và tăng tính chính xác của dữ liệu.

c. Phân quyền người dùng

Hệ thống SmartEMS được thiết kế với **hai nhóm người dùng chính**, bao gồm **Admin** và **Nhân viên**. Mỗi nhóm người dùng được cấp các quyền truy cập và sử dụng các chức năng khác nhau nhằm đảm bảo tính bảo mật, an toàn dữ liệu và phù hợp với vai trò của từng đối tượng.

d. Chức năng của Admin

Admin là người có quyền quản trị cao nhất trong hệ thống, chịu trách nhiệm quản lý và điều hành toàn bộ hoạt động của website. Các chức năng của Admin bao gồm:

- **Trang chủ:** Theo dõi tổng quan tình trạng hoạt động của hệ thống.
- **Điểm danh:** Quản lý và theo dõi dữ liệu chấm công của nhân viên.
- **Nghỉ phép:** Tiếp nhận, xét duyệt và quản lý các đơn xin nghỉ phép.
- **Lương thưởng:** Quản lý thông tin lương, thưởng và các khoản phụ cấp của nhân viên.
- **SHOP NẠP VIP:** Quản lý các gói dịch vụ và giao dịch nâng cấp.
- **Thông báo:** Tạo, chỉnh sửa và gửi thông báo đến nhân viên.
- **Dự án:** Tạo, phân công và quản lý các dự án của công ty.
- **Hợp đồng:** Tạo, lưu trữ và quản lý thông tin hợp đồng.
- **Quản lý Task:** Tạo, phân công và theo dõi tiến độ công việc của nhân viên.
- **ChatEMS:** Trao đổi thông tin với nhân viên thông qua hệ thống chat nội bộ.
- **HR:** Quản lý hồ sơ nhân viên, phòng ban, chức vụ, tài khoản người dùng và các nghiệp vụ nhân sự khác.

e. Chức năng của Nhân viên

Nhân viên sử dụng hệ thống để thực hiện các công việc hằng ngày và tra cứu các thông tin liên quan đến bản thân. Các chức năng của nhân viên bao gồm:

- **Trang chủ:** Xem thông tin tổng quan sau khi đăng nhập.

- **Điểm danh:** Thực hiện chấm công và theo dõi lịch sử điểm danh.
- **Nghỉ phép:** Gửi đơn xin nghỉ phép và theo dõi trạng thái phê duyệt.
- **Lương thưởng:** Xem thông tin lương, thưởng và các khoản liên quan.
- **SHOP NẠP VIP:** Sử dụng các gói dịch vụ hoặc nâng cấp tài khoản.
- **Thông báo:** Nhận và xem các thông báo từ công ty.
- **Dự án:** Xem các dự án được công ty phân công và theo dõi tiến độ thực hiện.
- **Hợp đồng:** Xem thông tin hợp đồng được công ty giao hoặc ký kết với bản thân.
- **Quản lý Task:** Xem, cập nhật và theo dõi tiến độ các công việc được giao.
- **ChatEMS:** Nền tảng AI Agent hỗ trợ người dùng Trao đổi thông tin và quản lý thông qua dữ liệu hệ thống được phép.

f. Tài sản cần bảo vệ

Trong quá trình vận hành, SmartEMS lưu trữ nhiều loại dữ liệu quan trọng của doanh nghiệp như thông tin cá nhân của nhân viên, tài khoản đăng nhập, mật khẩu, dữ liệu chấm công, lịch sử nghỉ phép, thông tin lương thưởng, hợp đồng, dự án, các công việc (Task) được giao và các dữ liệu phục vụ công tác quản lý nhân sự. Đây đều là những tài sản thông tin có giá trị, ảnh hưởng trực tiếp đến hoạt động, uy tín và sự phát triển của doanh nghiệp. Do đó, việc bảo vệ các dữ liệu này là yêu cầu thiết yếu nhằm đảm bảo **tính bảo mật (Confidentiality)**, **tính toàn vẹn (Integrity)** và **tính sẵn sàng (Availability)** của hệ thống, đồng thời ngăn chặn các nguy cơ truy cập trái phép, rò rỉ, sửa đổi hoặc mất mát dữ liệu.

g. Các rủi ro đối với hệ thống

Nếu hệ thống tồn tại các lỗ hổng bảo mật hoặc bị tấn công, doanh nghiệp có thể phải đối mặt với nhiều rủi ro như rò rỉ thông tin cá nhân của nhân viên, đánh cắp tài khoản người dùng, truy cập trái phép vào hệ thống, thay đổi

hoặc xóa dữ liệu quan trọng, làm sai lệch thông tin lương thưởng, giả mạo dữ liệu chấm công, chỉnh sửa trái phép thông tin hợp đồng, dự án hoặc công việc được giao, cũng như làm gián đoạn hoạt động của hệ thống. Những rủi ro này không chỉ ảnh hưởng đến quá trình quản lý và vận hành của doanh nghiệp mà còn làm suy giảm uy tín, gây thiệt hại về tài chính, ảnh hưởng đến quyền lợi của nhân viên và làm giảm mức độ tin cậy của hệ thống đối với người sử dụng.

1.2. Mục tiêu của Khung Quản lý Rủi ro (RMF)

Khung Quản lý Rủi ro (Risk Management Framework - RMF) là phương pháp tiếp cận có hệ thống, được sử dụng để nhận diện, đánh giá và xử lý các rủi ro an toàn thông tin trong một hệ thống, dựa trên nguyên lý chung được đề cập trong các tiêu chuẩn như NIST SP 800-37 và ISO/IEC 27005. Trong phạm vi báo cáo này, RMF được áp dụng nhằm đảm bảo quá trình đánh giá bảo mật hệ thống SmartEMS được thực hiện một cách khoa học, có căn cứ, thay vì chỉ dừng lại ở việc liệt kê các lỗi kỹ thuật rời rạc thiếu liên kết với bối cảnh vận hành thực tế của doanh nghiệp.

Việc áp dụng RMF trong báo cáo được thực hiện theo một quy trình tuần tự gồm 5 bước, trong đó đầu ra của bước trước là đầu vào của bước tiếp theo:

Bước 1 — Nhận diện rủi ro (Risk Identification)

Xác định một cách có hệ thống các lỗ hổng, điểm yếu tồn tại trong hệ thống SmartEMS, được phân loại theo nhóm nguyên nhân kỹ thuật: kiểm soát truy cập, xác thực và quản lý phiên làm việc, xử lý dữ liệu đầu vào, và cấu hình hệ thống. Đây là bước nền tảng, cung cấp danh mục đầu vào cho toàn bộ quy trình đánh giá phía sau.

Bước 2 — Đánh giá rủi ro (Risk Assessment)

Mỗi lỗ hổng được nhận diện ở bước 1 sẽ được lượng hóa dựa trên hai yếu tố độc lập: khả năng bị khai thác trong thực tế (Likelihood) và mức độ ảnh hưởng nếu bị khai thác thành công (Impact), theo công thức:

$$\text{Mức độ rủi ro} = \text{Khả năng khai thác} \times \text{Mức độ ảnh hưởng}$$

Kết quả được quy đổi thành ba mức ưu tiên: Cao, Trung bình và Thấp.

Bước 3 — Phân tích tác động đến doanh nghiệp (Business Impact Analysis)

Mỗi lỗ hổng đã được xếp hạng mức độ rủi ro tiếp tục được đối chiếu với hậu quả cụ thể có thể xảy ra đối với doanh nghiệp, xét trên ba khía cạnh của bộ ba an toàn thông tin (CIA): tính bí mật (confidentiality — rò rỉ thông tin lương thường, dữ liệu cá nhân), tính toàn vẹn (integrity — sai lệch, giả mạo dữ liệu nhân sự) và tính sẵn sàng (availability — gián đoạn hoạt động hệ thống).

Bước 4 — Đề xuất biện pháp xử lý rủi ro (Risk Treatment)

Dựa trên kết quả đánh giá và phân tích tác động ở hai bước trước, báo cáo đề xuất phương án xử lý phù hợp cho từng rủi ro theo một trong bốn hướng: khắc phục (mitigate), chấp nhận (accept), giảm thiểu thông qua thay đổi quy trình vận hành (reduce), hoặc chuyển giao rủi ro (transfer).

Bước 5 — Hỗ trợ ra quyết định (Decision Support)

Bước cuối cùng tổng hợp toàn bộ kết quả từ 4 bước trên thành một hồ sơ rủi ro (risk profile) tổng thể, có cấu trúc và định lượng được, làm cơ sở khách quan để doanh nghiệp phân bổ nguồn lực khắc phục theo đúng thứ tự ưu tiên, tránh tình trạng xử lý dàn trải hoặc bỏ sót các rủi ro nghiêm trọng.

PHẦN 2: Đánh giá rủi ro toàn diện (Comprehensive Risk Analysis)

2.1 Quy trình đánh giá rủi ro (Risk Assessment Process)

Để đánh giá rủi ro cho hệ thống SmartEMS một cách toàn diện, chúng tôi áp dụng quy trình 9 bước theo tiêu chuẩn NIST SP 800-30

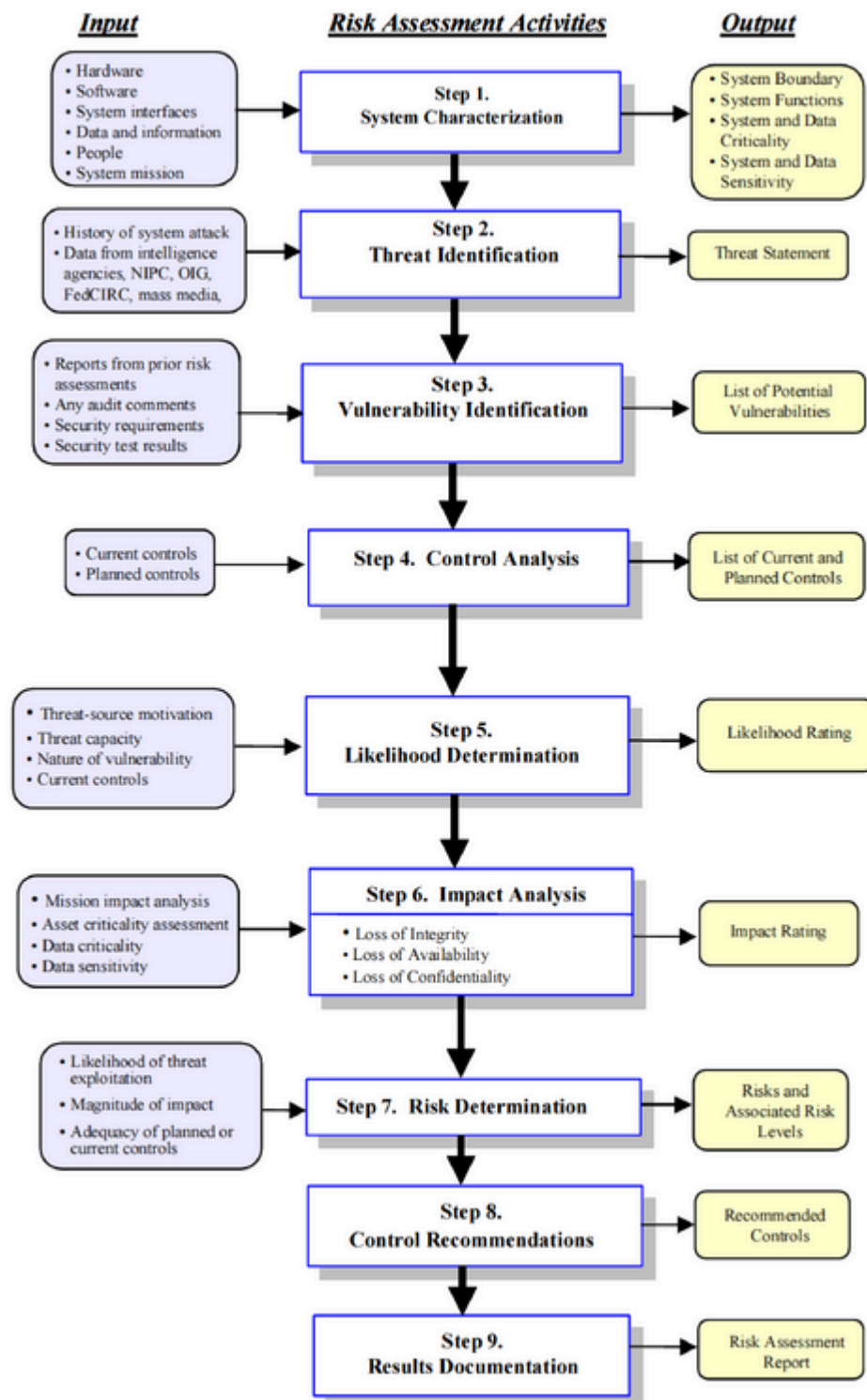


Figure 3-1. Risk Assessment Methodology Flowchart

1. **Đặc tả Hệ thống (System Characterization):** Xác định ranh giới phần cứng, phần mềm, luồng dữ liệu và người dùng của ứng dụng SmartEMS.
2. **Xác định Mối đe dọa (Threat Identification):** Nhận diện các tác nhân đe dọa (người dùng nội bộ cố ý/vô tình, hacker bên ngoài, lỗi kỹ thuật).
3. **Xác định Lỗ hổng (Vulnerability Identification):** Tìm kiếm các điểm yếu trong thiết kế kiến trúc và mã nguồn (đặc biệt là các lỗ hổng API, lưu trữ mật khẩu, quản lý phiên).
4. **Phân tích Biện pháp Kiểm soát (Control Analysis):** Đánh giá các biện pháp phòng ngừa hoặc phát hiện hiện có (như phân quyền dựa trên Session, xác thực đầu vào sơ sài).
5. **Xác định Khả năng xảy ra (Likelihood Determination):** Đánh giá xác suất một mối đe dọa có thể khai thác thành công lỗ hổng (Thấp - Trung bình - Cao).
6. **Phân tích Tác động (Impact Analysis):** Đo lường mức độ thiệt hại đối với các khía cạnh CIA (Confidentiality - Tính bảo mật, Integrity - Tính toàn vẹn, Availability - Tính sẵn sàng) nếu rủi ro xảy ra.
7. **Xác định Mức độ Rủi ro (Risk Determination):** Tính toán điểm rủi ro bằng công thức định tính: **Risk Level = Probability (Likelihood) x Impact**
8. **Đề xuất Biện pháp Kiểm soát (Control Recommendations):** Lựa chọn các giải pháp kỹ thuật và hành chính phù hợp để giảm thiểu rủi ro xuống mức chấp nhận được.
9. **Tài liệu hóa Kết quả (Results Documentation):** Lập báo cáo đánh giá rủi ro gửi ban quản trị doanh nghiệp phê duyệt.

2.2 Xác định tài sản (Asset Identification)

Tài sản của hệ thống SmartEMS được phân loại dựa trên 7 Domains của Cơ sở hạ tầng CNTT điển hình:

Domain	Tài sản cụ thể của SmartEMS	Giá trị phi tiền tệ / Phân loại bảo mật	Ghi chú
User Domain	- Tài khoản quản trị (admin). - Tài khoản nhân viên. - Thông tin đăng nhập, phiên làm việc (Session Cookies).	Critical (Quy chuẩn bảo mật) Yêu cầu bảo mật cao chống chiếm quyền điều khiển.	Người dùng là mắt xích yếu nhất trong hệ thống bảo mật (Chương 1).
Workstation Domain	- Trình duyệt máy khách truy cập SmartEMS. - Lịch sử bộ nhớ cache, thông tin đăng nhập lưu trên máy trạm.	Medium Có nguy cơ bị khai thác nếu máy trạm bị nhiễm malware hoặc để hở màn hình.	Rủi ro mất mát thiết bị hoặc rò rỉ session tại máy trạm.
LAN Domain	- Mạng nội bộ kết nối máy trạm nhân viên đến máy chủ chạy app Flask.	Medium Rủi ro nghe lén (Sniffing) dữ liệu truyền qua HTTP không mã hóa.	Sử dụng switch thay hub để hạn chế sniffing (Chương 1).
LAN-to-WAN Domain	- Thiết bị định tuyến và tường	Critical Bảo vệ biên	Cần áp dụng quy tắc chặn

	lửa kết nối Internet.	mạng của doanh nghiệp chống lại tấn công từ Internet.	mặc định (Implicit Deny).
WAN Domain	- Kết nối Internet công cộng dẫn tới máy chủ.	Medium Vùng không tin cậy.	Đối mặt với nguy cơ tấn công DoS/DDoS.
Remote Access Domain	- Truy cập của nhân viên làm việc từ xa (Work from home).	High Cần xác thực đa yếu tố và kênh truyền mã hóa (VPN/HTTPS).	Dữ liệu truyền tải có nguy cơ bị đánh cắp trên mạng công cộng.
System/Application Domain	- Mã nguồn ứng dụng Python/Flask (app.py, controllers, models). - Cơ sở dữ liệu dạng file JSON (employees.json, project_files.json, salaries.json...). - Công cụ sinh tài liệu (python-docx). - Máy chủ Web/App, ERP/CRM, Storage	Critical / Proprietary (Tuyệt mật) Chứa toàn bộ dữ liệu nhạy cảm (thông tin cá nhân PII, lương, dự án nội bộ).	Đây là trái tim của hệ thống SmartEMS, yêu cầu bảo vệ cao nhất.

2.3. Xác định Mối đe dọa & Lỗ hổng (Threat & Vulnerability Identification)

A. Xác định Mối đe dọa (Threats)

Dựa vào phương pháp brainstorming và phân tích lịch sử, các mối đe dọa chính đối với SmartEMS gồm:

1. Mối đe dọa từ con người cố ý (Human Intentional - Nội bộ):
 - Nhân viên không có quyền truy cập dự án nhưng cố tình tìm cách đọc tài liệu mật trên server để trục lợi hoặc bán cho đối thủ cạnh tranh.
 - Nhân viên gian lận tài chính bằng cách can thiệp vào tiến trình mua sắm vật phẩm (Shop) hoặc can thiệp dữ liệu điểm danh, lương.
2. Mối đe dọa từ con người cố ý (Human Intentional - Bên ngoài):
 - Hacker tấn công vét cạn (brute-force) tài khoản admin để chiếm quyền kiểm soát toàn bộ hệ thống.
 - Hacker tấn công khai thác lỗi mã nguồn để đánh cắp toàn bộ file dữ liệu JSON.
3. Mối đe dọa vô tình (Human Unintentional):
 - Nhân viên vô tình đặt mật khẩu quá yếu (123456, admin123) giúp kẻ tấn công dễ dàng dò quét.
 - Lỗi lập trình viên không áp dụng cơ chế khóa tệp (file lock) dẫn đến tranh chấp tài nguyên (Race Condition) làm mất mát dữ liệu hoặc làm hỏng cấu trúc tệp JSON (Data Corruption).

B. Xác định Lỗ hổng (Vulnerabilities)

Qua phân tích kiến trúc SmartEMS, chúng tôi phát hiện các lỗ hổng hệ thống nghiêm trọng sau:

- 1. Thiết kế kiểm soát truy cập yếu (Broken Access Control): Các endpoint API quan trọng liên quan đến tệp tin dự án không kiểm tra quyền thành viên.
- 2. Lưu trữ mật khẩu không an toàn (Insecure Cryptographic Storage): Sử dụng hàm băm SHA-256 thuần túy không có muối (salt).
- 3. Chính sách mật khẩu lỏng lẻo (Weak Password Policy): Backend chỉ kiểm tra độ dài tối thiểu 6 ký tự mà không yêu cầu độ phức tạp.
- 4. Không có cơ chế xử lý tranh chấp đồng thời (Lack of Concurrency Locking): Việc đọc/ghi dữ liệu JSON diễn ra tuần tự thông qua I/O file thông thường, dễ bị tấn công Race Condition.

2.4. Phân tích và Đánh giá Rủi ro (Risk Assessment)

Áp dụng phương pháp đánh giá rủi ro định tính kết hợp định lượng, chúng tôi thiết lập Ma trận Đánh giá Rủi ro dưới đây.

Khả năng xảy ra (Likelihood) được đánh giá từ 0.1 (Thấp) đến 1.0 (Cao). Tác động (Impact) được đánh giá từ 10 (Thấp) đến 100 (Cao). Điểm rủi ro cuối cùng được xếp hạng từ 1 đến 100.

Bảng Phân tích Cặp Mối đe dọa - Lỗ hổng (Threat/Vulnerability Pairs) và Đánh giá Rủi ro

Mã	Cặp mối đe dọa - Lỗ hổng	Hậu quả (impacted Area)	Xác suất (L)	Tác động (I)	Điểm Rủi ro (L x I)	Xếp hạng Rủi ro
----	--------------------------	-------------------------	--------------	--------------	---------------------	-----------------

R1	Hacker/Nhân viên không có quyền khai thác lỗ hổng BOLA/IDOR trong API quản lý file dự án.	Rò rỉ toàn bộ tài liệu thiết kế và mã nguồn tuyệt mật của các dự án đang phát triển (Mất tính Bảo mật - C).	0.9	100	90	Critical
R2	Kẻ tấn công bẻ khóa mật khẩu người dùng do hệ thống băm SHA-256 không salt kết hợp mật khẩu yếu.	Chiếm quyền điều khiển tài khoản của nhân viên hoặc quản trị viên (Mất tính Bảo mật và Toàn vẹn - C & I).	0.8	100	80	High
R3	Người dùng gửi các request đồng thời để tận dụng Race Condition trong tính năng mua sắm (Shop).	Gian lận số dư lương, mua đồ không mất tiền hoặc mua vượt quá số lượng tồn kho thực tế (Mất tính Toàn vẹn - I).	0.6	50	30	Medium
R4	Nhiều luồng ghi dữ liệu đồng thời vào file	Tập dữ liệu JSON bị ghi đè, lỗi định dạng khiến	0.5	100	50	High

	database JSON không có cơ chế File Locking.	toàn bộ ứng dụng bị sập, ngừng hoạt động (Mất tính Sẵn sàng - A).				
R5	Kẻ tấn công tải lên file có chứa các ký tự di chuyển đường dẫn (../..) gây ra lỗi Zip Slip.	Khi admin xuất ZIP các file dự án và giải nén, file độc hại có thể ghi đè lên các tệp cấu hình của hệ thống máy chủ.	0.3	100	30	Medium

PHẦN 3: ĐỀ XUẤT CHIẾN LƯỢC GIẢM THIỂU RỦI RO

Dựa trên kết quả đánh giá rủi ro tại Phần 2 (5 cặp mối đe dọa – lỗ hổng R1–R5), Phần 3 đề xuất chiến lược giảm thiểu rủi ro toàn diện cho hệ thống SmartEMS bao gồm:

- phân tích chi phí – lợi ích
- các biện pháp kiểm soát kỹ thuật và quản lý cụ thể
- ánh xạ các biện pháp này với các chuẩn quốc tế COBIT, NIST CSF và ISO/IEC 27001

3.1. Phân tích Chi phí – Lợi ích (Cost-Benefit Analysis)

Với mỗi rủi ro đã xác định ở Phần 2, nhóm đề xuất biện pháp kiểm soát tương ứng, ước tính chi phí triển khai và mức giảm điểm rủi ro (Residual Risk) sau khi áp dụng kiểm soát, làm cơ sở ưu tiên đầu tư nguồn lực.

Mã	Biện pháp kiểm soát đề xuất	Chi phí ước tính	Điểm rủi ro trước	Đánh giá Cost-Benefit
R1	Bổ sung kiểm tra phân quyền cấp đối tượng (object-level authorization) tại mọi API endpoint file dự án	Thấp (~2–3 ngày)	90 (Critical)	Rất cao — chi phí thấp, giảm rủi ro Critical gần như triệt để
R2	Chuyển từ SHA-256 thuần sang bcrypt/Argon2 có salt tự động	Thấp (thay thư viện băm, migrate dữ liệu cũ)	80 (High)	Rất cao — chi phí thấp, ngăn brute-force/rainbow table hiệu quả
R2	Áp dụng chính sách mật khẩu mạnh (≥ 8 ký tự, có chữ hoa/số/ký tự đặc biệt) + khóa tài khoản sau N lần đăng nhập sai	Thấp	(kết hợp với trên)	Cao — chi phí gần bằng 0, hiệu quả cộng dồn tốt
R3, R4	Triển khai cơ chế khóa tệp (file locking) hoặc chuyển sang CSDL có transaction (SQLite/PostgreSQL)	Trung bình (~1–2 tuần)	50 / 30	Cao — chi phí trung bình nhưng loại bỏ hoàn toàn nguy cơ Data Corruption
R5	Kiểm tra và chuẩn hóa đường dẫn khi giải nén ZIP (chặn path traversal ../)	Thấp (bổ sung hàm validate)	30 (Medium)	Cao — chi phí thấp, ngăn chặn hoàn toàn lỗi Zip Slip

Kết luận: R1 và R2 nên được xử lý ngay lập tức vì đều là lỗ hổng Critical/High nhưng chi phí khắc phục thấp, tỷ suất lợi ích trên chi phí

(benefit-cost ratio) cao nhất. R3/R4 tuy chi phí cao hơn nhưng cần thiết vì ảnh hưởng trực tiếp đến tính sẵn sàng (Availability) của toàn hệ thống.

3.2. Các Biện pháp Kiểm soát Đề xuất

Các biện pháp kiểm soát được chia theo hai nhóm: kiểm soát kỹ thuật (technical controls) và kiểm soát quản lý (administrative/managerial controls), tương ứng với từng lỗ hổng đã nêu tại mục 2.3.B.

a. Kiểm soát kỹ thuật (Technical Controls)

1. Chống Broken Access Control (R1):

- Áp dụng middleware kiểm tra quyền sở hữu/phân quyền trên mọi request đến API file/dự án (kiểm tra user_id/role khớp với tài nguyên được truy cập, không chỉ dựa vào việc đã đăng nhập).
- Áp dụng nguyên tắc Least Privilege trong thiết kế route Flask.

2. Chống Insecure Cryptographic Storage (R2):

- Thay thế SHA-256 thuần bằng bcrypt hoặc argon2 (có salt ngẫu nhiên, cost factor điều chỉnh được).
- Mã hóa dữ liệu nhạy cảm khác (lương, thông tin cá nhân) khi lưu trong file JSON.

3. Chống Weak Password Policy:

- Ràng buộc độ phức tạp mật khẩu ở cả frontend và backend.
- Cân nhắc bổ sung xác thực đa yếu tố (MFA) cho tài khoản admin.

4. Chống Race Condition / Data Corruption (R3, R4):

- Sử dụng cơ chế file locking (VD: thư viện filelock trong Python) khi ghi file JSON.
- Về lâu dài, khuyến nghị migrate từ lưu trữ file JSON sang CSDL quan hệ nhẹ (SQLite) hỗ trợ transaction ACID.

5. Chống Zip Slip (R5):

- Validate từng path trong file ZIP trước khi giải nén, từ chối các path chứa ../ hoặc path tuyệt đối, đảm bảo path đích luôn nằm trong thư mục cho phép.

6. Kiểm soát bổ sung cho toàn hệ thống:

- Bắt buộc HTTPS/TLS cho toàn bộ traffic (khắc phục rủi ro sniffing ở LAN Domain đã nêu ở mục 2.2).
- Cấu hình tường lửa với chính sách Implicit Deny ở LAN-to-WAN Domain.
- Giới hạn tốc độ request (rate limiting) để giảm nguy cơ brute-force và DoS.

b. Kiểm soát quản lý (Administrative Controls)

- Chính sách kiểm soát truy cập (Access Control Policy): quy định rõ ai được cấp quyền gì, review định kỳ.
- Đào tạo nhận thức bảo mật (Security Awareness Training) cho nhân viên, đặc biệt về đặt mật khẩu mạnh.
- Quy trình rà soát mã nguồn (Code Review / Secure SDLC) trước khi deploy, để phát hiện sớm các lỗi như R1, R5.
- Chính sách sao lưu định kỳ (Backup Policy) cho dữ liệu JSON, làm nền cho DRP ở Phần 4.
- Chính sách quản lý bản vá (Patch Management) cho các thư viện Python (requirements.txt) để tránh lỗi hỏng từ dependency cũ.

3.3. Ánh xạ với Chuẩn Quốc tế (Mapping)

Bảng dưới đây ánh xạ từng biện pháp kiểm soát đề xuất tại mục 3.2 với các điều khoản tương ứng trong ISO/IEC 27001:2022 (Annex A), NIST CSF 2.0 và COBIT 2019.

Biện pháp kiểm soát	ISO/IEC 27001:2022 (Annex A)	NIST CSF 2.0	COBIT 2019
Object-level authorization (R1)	A.8.3 – Information access restriction	PROTECT (PR.AA)	APO13 – Managed Security
Mã hóa mật khẩu bcrypt/Argon2 (R2)	A.8.24 – Use of cryptography	PROTECT (PR.DS)	DSS05 – Managed Security Services
Chính sách mật khẩu mạnh + MFA	A.5.17, A.8.5 – Authentication information	PROTECT (PR.AA)	APO13
File locking / migrate DB (R3, R4)	A.8.16 – Monitoring activities; A.8.24	PROTECT (PR.DS), RECOVER (RC.RP)	BAI09 – Managed Assets
Kiểm tra path khi giải nén (R5)	A.8.28 – Secure coding	PROTECT (PR.PS)	BAI03 – Managed Solutions Identification/Build
HTTPS/TLS, tường lửa, rate limiting	A.8.20 – Network security; A.8.22	PROTECT (PR.IR)	DSS05
Đào tạo nhận thức bảo mật	A.6.3 – Awareness/training	PROTECT (PR.AT)	APO07 – Managed Human Resources
Code review / Secure SDLC	A.8.25 – Secure development lifecycle	IDENTIFY (ID.RA), PROTECT	BAI03
Backup policy	A.8.13 – Information backup	RECOVER (RC.RP)	DSS04 – Managed Continuity

Patch management	A.8.8 – Management of technical vulnerabilities	IDENTIFY (ID.RA), PROTECT	BAI03, DSS05
------------------	---	---------------------------	--------------

PHẦN 4: RESPONSE & RECOVERY ANNEXES

4.1. Business Impact Analysis (BIA)

Business Impact Analysis (BIA) là quá trình xác định các chức năng nghiệp vụ quan trọng của hệ thống, đánh giá mức độ ảnh hưởng khi xảy ra gián đoạn và xác định các mục tiêu khôi phục phù hợp. Theo hướng dẫn của **NIST SP 800-34 Rev.1**, BIA là nền tảng để xây dựng **Business Continuity Plan (BCP)** và **Disaster Recovery Plan (DRP)**, giúp tổ chức ưu tiên nguồn lực và lựa chọn chiến lược phục hồi phù hợp với mức độ quan trọng của từng dịch vụ.

Đối với hệ thống **SmartEMS**, BIA được thực hiện dựa trên kiến trúc ứng dụng Flask, cơ chế lưu trữ dữ liệu bằng JSON và các chức năng quản lý nhân sự hiện có. Các nghiệp vụ được đánh giá bao gồm xác thực người dùng, quản lý nhân viên, chấm công, nghỉ phép, quản lý tiền lương, quản lý hợp đồng, quản lý dự án, quản lý công việc và trợ lý AI nội bộ (ChatEMS).

Phân tích mức độ ảnh hưởng

Nghệp vụ	Tác động khi ngừng hoạt động	Mức độ
Authentication & OTP	Người dùng không thể xác thực và truy cập hệ thống.	Critical
Employee Management	Không thể quản lý thông tin nhân viên.	High
Attendance Management	Không thể ghi nhận thời gian làm việc.	High
Salary Management	Ảnh hưởng đến việc tính toán và thanh toán lương.	Critical

Project Management	Ảnh hưởng đến tiến độ triển khai dự án.	Medium
Task Management	Không thể giao, theo dõi và cập nhật công việc.	High
Contract Management	Không thể truy cập và quản lý hợp đồng lao động.	Critical
Notification Service	Không thể gửi thông báo đến người dùng.	Medium
ChatEMS (AI Assistant)	Người dùng không thể sử dụng chức năng hỗ trợ AI nội bộ.	Low

Quan hệ phụ thuộc giữa các nghiệp vụ

Các chức năng trong SmartEMS có mối quan hệ phụ thuộc với nhau. Khi một chức năng bị gián đoạn, các chức năng phụ thuộc cũng có thể bị ảnh hưởng. Các mối quan hệ phụ thuộc chính được xác định như sau:

- **Authentication & OTP** ngừng hoạt động → Người dùng không thể truy cập các chức năng khác của hệ thống.
- **Employee Management** ngừng hoạt động → Không thể quản lý nhân viên, chấm công, nghỉ phép, hợp đồng và tiền lương.
- **Attendance Management** ngừng hoạt động → Không thể ghi nhận dữ liệu chấm công và tính lương chính xác.
- **Project Management** ngừng hoạt động → Không thể giao hoặc theo dõi các nhiệm vụ (Task).
- **Salary Management** ngừng hoạt động → Không thể tính toán và quản lý bảng lương.
- **Contract Management** ngừng hoạt động → Không thể tra cứu hoặc quản lý hợp đồng lao động.
- **ChatEMS (AI Assistant)** ngừng hoạt động → Chỉ ảnh hưởng đến chức năng hỗ trợ AI, không ảnh hưởng đến các nghiệp vụ cốt lõi.

Mục tiêu khôi phục

Business Function	RTO	RPO	Recovery Priority
-------------------	-----	-----	-------------------

Authentication & OTP	30 minutes	0 minutes	1
Salary Management	2 hours	30 minutes	2
Contract Management	2 hours	15 minutes	3
Attendance Management	4 hours	1 hour	4
Task Management	4 hours	30 minutes	5
Leave Management	8 hours	2 hours	6
Notification System	8 hours	2 hours	7
Employee Management	8 hours	2 hours	8
Project Management	12 hours	4 hours	9
ChatEMS (AI Assistant)	12 hours	4 hours	10

Kết quả BIA cho thấy Authentication, Salary và Contract Management là ba thành phần cần được ưu tiên khôi phục nhằm đảm bảo hoạt động liên tục của doanh nghiệp.

Kết luận: Kết quả Business Impact Analysis cho thấy **Authentication & OTP, Salary Management và Contract Management** là ba chức năng có mức độ ưu tiên khôi phục cao nhất do ảnh hưởng trực tiếp đến hoạt động của toàn bộ hệ thống SmartEMS. Các chức năng như **Attendance Management, Task Management và Employee Management** được khôi phục ở giai đoạn tiếp theo nhằm đảm bảo tính liên tục của các nghiệp vụ nhân sự.

4.2. Business Continuity Plan (BCP)

Business Continuity Plan (BCP) được xây dựng nhằm đảm bảo các hoạt động nghiệp vụ quan trọng của SmartEMS vẫn có thể được duy trì khi xảy ra sự cố làm gián đoạn hệ thống. Mục tiêu của BCP là giảm thiểu ảnh hưởng đến hoạt động của doanh nghiệp, duy trì

các chức năng thiết yếu và hỗ trợ quá trình khôi phục theo các giá trị RTO và RPO đã xác định trong Business Impact Analysis (BIA).

Các tình huống giả định

Mã sự cố	Mô tả sự cố	Mức độ ảnh hưởng
BCP-01	Máy chủ ứng dụng Flask ngừng hoạt động, khiến người dùng không thể truy cập hệ thống SmartEMS.	High
BCP-02	Dữ liệu lưu trữ trên JSON bị hỏng, mất hoặc không thể truy xuất.	Critical
BCP-03	Hệ thống bị tấn công DoS/DDoS, làm gián đoạn hoặc suy giảm hiệu năng dịch vụ.	High
BCP-04	Tài khoản quản trị viên (Admin) bị chiếm quyền, dẫn đến nguy cơ thay đổi hoặc đánh cắp dữ liệu.	Critical
BCP-05	Dữ liệu hợp đồng lao động và thông tin nhân viên bị rò rỉ hoặc truy cập trái phép.	Critical
BCP-06	Dữ liệu của chức năng Task Management bị mất hoặc không thể khôi phục đầy đủ.	Medium

Kế hoạch duy trì hoạt động

Hoạt động	Phương án thay thế 1	Phương án thay thế 2	Phương án thay thế 3
Chấm công	Biểu mẫu giấy thủ công	Google Forms	File Excel/Google Sheets dùng chung
Giao nhiệm vụ	Email nội bộ	Microsoft Teams	Nhóm Zalo/Slack
Quản lý hợp đồng	Sử dụng bản PDF đã sao lưu	Lưu trữ trên Cloud (Google Drive/OneDrive)	Bản in cứng tại phòng Nhân sự

Quản lý lương	Khôi phục từ bản backup gần nhất	Xử lý bằng bảng tính Excel	Đối chiếu với dữ liệu ngân hàng và HR
Nghỉ phép	Tiếp nhận qua Email	Phiếu đề xuất nghỉ phép giấy	Microsoft Forms/Google Forms
Quản lý dự án	Spreadsheet (Excel/Google Sheets)	Microsoft Project	Trello hoặc Jira
Quản lý nhân viên	Danh sách nhân sự sao lưu định kỳ	File Excel ngoại tuyến	Truy xuất từ bản backup Cloud
Thông báo nội bộ	Email hàng loạt	Microsoft Teams	Nhóm Zalo doanh nghiệp
Xác thực người dùng	Tài khoản dự phòng cho quản trị viên	Xác thực tạm thời bằng Email	Kích hoạt cơ chế đăng nhập khẩn cấp (Emergency Access)
Quản lý Task	File Excel theo dõi công việc	Trello/Kanban Board	Họp giao ban và cập nhật thủ công

Vai trò trong BCP

Vai trò	Trách nhiệm
Incident Manager	Kích hoạt BCP, điều phối các bộ phận liên quan và giám sát quá trình duy trì hoạt động kinh doanh.
System Administrator	Duy trì hạ tầng CNTT, đảm bảo tính sẵn sàng của máy chủ, mạng và các dịch vụ quan trọng.
Security Team	Điều tra nguyên nhân sự cố, giám sát an toàn thông tin và hỗ trợ xử lý các rủi ro phát sinh.
HR Department	Đảm bảo các hoạt động nhân sự được duy trì liên tục và hỗ trợ truyền thông nội bộ đến nhân viên.
Team Leader	Phân công công việc, theo dõi tiến độ của nhóm và báo cáo tình hình hoạt động trong thời gian xảy ra sự cố.

Chính sách sao lưu

Chính sách	Giá trị
Backup Schedule	Hàng ngày lúc 23:00
Backup Versions	07 phiên bản gần nhất
Backup Location	Local + External + Cloud
Restore Testing	Kiểm tra khả năng khôi phục định kỳ hàng tháng

Business Continuity Plan giúp SmartEMS duy trì các hoạt động nghiệp vụ quan trọng trong thời gian xảy ra sự cố, đồng thời giảm thiểu ảnh hưởng đến người dùng và doanh nghiệp. Kế hoạch này kết hợp với kết quả BIA để xác định thứ tự ưu tiên khôi phục, phân công trách nhiệm cho từng bộ phận và chuẩn bị các phương án thay thế nhằm đảm bảo tính liên tục của hoạt động kinh doanh.

4.3. Disaster Recovery Plan (DRP)

Disaster Recovery Plan (DRP) tập trung vào việc khôi phục hệ thống sau các sự cố nghiêm trọng.

Các thành phần cần khôi phục:

Thành phần	Vị trí lưu trữ	Mức độ ưu tiên	Phương thức khôi phục
Flask Application	app.py	Critical	Khôi phục từ Git Repository hoặc máy chủ dự phòng

Controllers	<code>controller/*</code>	High	Đồng bộ lại từ Git và kiểm tra API endpoints
Models	<code>model/*</code>	High	Khôi phục từ Git, kiểm tra tính tương thích dữ liệu
Views (HTML/CSS/JS)	<code>view/*</code>	High	Triển khai lại giao diện từ source code
Database JSON	<code>data/*.json</code>	Critical	Restore từ bản backup gần nhất và kiểm tra tính toàn vẹn
Employee Data	<code>employees.json</code>	Critical	Khôi phục từ backup và đối chiếu với hồ sơ nhân sự
Contract Data	<code>contracts.json</code>	Critical	Phục hồi từ bản sao lưu mã hóa hoặc Cloud Storage
Salary Data	<code>salaries.json</code>	Critical	Khôi phục từ backup và xác minh với bộ phận HR
Task Data	<code>tasks.json</code>	High	Restore từ backup hằng ngày hoặc lịch sử thay đổi
Project Data	<code>projects.json</code>	High	Đồng bộ lại từ bản sao lưu gần nhất
Notification & OTP	<code>notifications.json, otp_codes.json</code>	Medium	Khởi tạo lại dữ liệu và hủy các OTP cũ
Pentest Reports	<code>pentest/*</code>	Medium	Khôi phục từ kho lưu trữ tài liệu dự án
RMF Documents	<code>docs/rrm/*</code>	Medium	Khôi phục từ hệ thống quản lý tài liệu hoặc Git

Chiến lược địa điểm dự phòng (Recovery Site Strategy)

DR Site	Mô tả	Thời gian khôi phục	Áp dụng cho SmartEMS
Cold Site	Chỉ có hạ tầng cơ bản, triển khai lại Flask và phục hồi dữ liệu từ bản sao lưu khi xảy ra sự cố.	Dài (24–48 giờ)	Phù hợp khi ngân sách hạn chế.

Warm Site	Có sẵn máy chủ dự phòng, môi trường Flask và cơ sở dữ liệu; chỉ cần đồng bộ source code và khôi phục dữ liệu từ backup.	Trung bình (2–8 giờ)	Đề xuất cho SmartEMS.
Hot Site	Hệ thống dự phòng hoạt động song song và đồng bộ dữ liệu gần thời gian thực.	Rất ngắn (vài phút)	Không ưu tiên do chi phí cao và vượt nhu cầu hiện tại.

Recovery Testing

Hoạt động kiểm thử	Mục đích	Chu kỳ
Restore Backup	Kiểm tra khả năng khôi phục dữ liệu từ bản sao lưu	Hàng tháng
Disaster Recovery Simulation	Mô phỏng sự cố mất máy chủ hoặc hỏng dữ liệu và đánh giá quy trình DRP	6 tháng/lần
Business Continuity Exercise	Kiểm tra khả năng duy trì các nghiệp vụ quan trọng theo BCP	1 năm/lần
Incident Response Exercise	Diễn tập quy trình ứng cứu của CIRT đối với các tình huống tấn công mạng	6 tháng/lần

Bài học kinh nghiệm

Theo nguyên tắc Continuous Improvement của NIST và ISO 22301, mỗi sự cố hoặc cuộc diễn tập đều là cơ hội để hoàn thiện năng lực phục hồi của tổ chức. Sau khi quá trình khôi phục hoàn tất, nhóm phụ trách tiến hành họp đánh giá sau sự cố (Post-Incident Review) nhằm xem xét hiệu quả của các biện pháp đã triển khai, những khó khăn gặp phải và các nội dung cần cải tiến.

Các bài học kinh nghiệm được ghi nhận sẽ được sử dụng để cập nhật quy trình ứng cứu, kế hoạch sao lưu, kế hoạch khôi phục, tài liệu hướng dẫn và chương trình đào tạo. Việc cải tiến liên tục giúp rút ngắn thời gian khôi phục, giảm thiểu thiệt hại và nâng cao khả năng sẵn sàng của SmartEMS trước các sự cố trong tương lai.

4.4. Computer Incident Response Team (CIRT)

Nhóm xây dựng Computer Incident Response Team (CIRT) nhằm đảm bảo khả năng phản ứng và phục hồi trước các sự cố an toàn thông tin.

Cơ cấu đội CIRT

Vai trò	Nhiệm vụ
CIRT Leader	Điều phối hoạt động ứng cứu, phân công nhiệm vụ và báo cáo tình hình sự cố.
Security Analyst	Phân tích log, thu thập bằng chứng và xác định nguyên nhân sự cố.
System Administrator	Cô lập, khôi phục hệ thống và đảm bảo dịch vụ hoạt động ổn định.
Developer	Khắc phục lỗi hỏng, rà soát mã nguồn và triển khai bản vá.
HR Representative	Thông báo tới nhân viên và hỗ trợ các hoạt động liên quan đến nhân sự.

Quy trình ứng cứu

Giai đoạn	Hoạt động
Preparation	Chuẩn bị chính sách bảo mật, CIRT, RMF, BCP/DRP, hệ thống backup và các công cụ giám sát (Burp Suite, Wireshark, Wazuh, Nmap).
Detection & Analysis	Phát hiện sự cố, phân tích log, xác định phạm vi ảnh hưởng và thu thập bằng chứng.
Containment	Khóa tài khoản bị ảnh hưởng, chặn IP độc hại, cô lập dịch vụ hoặc máy chủ để ngăn sự cố lan rộng.
Eradication	Loại bỏ nguyên nhân bằng cách vá lỗ hổng, cập nhật hệ thống, rà soát mã nguồn và thay đổi thông tin xác thực nếu cần.
Recovery	Khôi phục dữ liệu từ backup, kiểm tra tính toàn vẹn và đưa hệ thống trở lại hoạt động, đồng thời tiếp tục giám sát.
Lessons Learned	Đánh giá sau sự cố, phân tích nguyên nhân gốc, cập nhật Risk Register, RMF, BCP/DRP và cải thiện quy trình ứng cứu.

Mức độ ưu tiên xử lý

Mức độ	Ví dụ	Mục tiêu xử lý
--------	-------	----------------

Critical	Mất dữ liệu, hệ thống ngừng hoạt động, tài khoản Admin bị chiếm quyền	Xử lý ngay lập tức
High	Broken Access Control, rò rỉ dữ liệu, DoS	Ưu tiên xử lý trong thời gian ngắn
Medium	Lỗi chức năng, Race Condition, OTP bất thường	Xử lý theo kế hoạch
Low	Lỗi giao diện, cảnh báo không ảnh hưởng bảo mật	Theo dõi và khắc phục khi phù hợp

→ Việc xây dựng CIRT giúp SmartEMS hình thành quy trình ứng cứu thống nhất từ phát hiện, xử lý đến khôi phục sau sự cố. Đồng thời, hoạt động đánh giá sau sự cố và cải tiến liên tục góp phần nâng cao năng lực bảo vệ hệ thống và giảm thiểu rủi ro trong các lần vận hành tiếp theo.

4.5. Kết luận

Việc xây dựng **Business Impact Analysis (BIA)**, **Business Continuity Plan (BCP)**, **Disaster Recovery Plan (DRP)** và **Computer Incident Response Team (CIRT)** giúp SmartEMS nâng cao khả năng ứng phó với các sự cố an toàn thông tin và đảm bảo tính liên tục của hoạt động kinh doanh. Các kế hoạch này hỗ trợ doanh nghiệp giảm thiểu tác động của sự cố, khôi phục hệ thống theo các mục tiêu RTO và RPO, đồng thời cải tiến quy trình thông qua đánh giá sau sự cố và kiểm thử định kỳ. Đây là nền tảng quan trọng để SmartEMS vận hành an toàn, ổn định và đáp ứng các yêu cầu của NIST và ISO về quản lý rủi ro, ứng cứu sự cố và phục hồi hệ thống.

PHẦN 5: AI USAGE REFLECTION

5.1. Bảng tổng hợp việc sử dụng AI trong dự án

#	Công đoạn sử dụng AI	Mục đích / Lý do	Công cụ AI	Kết quả có đáng tin không?	Phương pháp xác minh
1	Xây dựng khung phân tích RMF 5 bước (mục 1.2) và áp dụng quy trình đánh giá rủi ro 9 bước theo NIST SP 800-30 (mục 2.1)	Hệ thống hóa quy trình đánh giá theo chuẩn quốc tế, thay vì liệt kê lỗi kỹ thuật rời rạc	Claude, DeepSeek	Đáng tin ở mức khung phương pháp luận	Đối chiếu trực tiếp cấu trúc các bước với tài liệu gốc NIST SP 800-30 và NIST SP 800-37
2	Nhận diện tài sản, mối đe dọa và lỗ hổng theo 7 Domain hạ tầng CNTT áp dụng cho kiến trúc Flask + JSON của SmartEMS (mục 2.2, 2.3)	Hỗ trợ liệt kê các nhóm lỗ hổng kỹ thuật (kiểm soát truy cập, lưu trữ mật khẩu, race condition..)	Claude, DeepSeek	Đáng tin về mặt phân loại lý thuyết; chi tiết kỹ thuật cụ thể cần kiểm chứng lại	Đối chiếu lại với mã nguồn thực tế của dự án trên GitHub (các file controller, util) trước khi đưa vào báo cáo
3	Lượng hóa rủi ro theo công thức $Risk = Likelihood \times Impact$ và xếp hạng Critical/High/Medium (mục 2.4)	Chuẩn hóa cách chấm điểm để so sánh mức độ ưu tiên xử lý giữa các lỗ hổng R1-R5	Claude, DeepSeek	Đáng tin về logic tính toán; các con số Likelihood/Impact cụ thể mang tính ước	Nhóm/bản thân tự rà soát và điều chỉnh lại điểm số theo đánh giá thực tế, không giữ

				lượng ban đầu	nguyên đề xuất ban đầu
4	Ánh xạ các biện pháp kiểm soát với ISO/IEC 27001:2022, NIST CSF 2.0 và COBIT 2019 (mục 3.3)	Đảm bảo các đề xuất kỹ thuật có căn cứ tuân thủ theo chuẩn quốc tế được công nhận	Claude, DeepSeek	Đáng tin ở việc ánh xạ đúng nhóm điều khoản; mã điều khoản cụ thể cần kiểm tra lại theo phiên bản chuẩn	Đối chiếu với tài liệu chính thức ISO/IEC 27001:2022 (Annex A), NIST CSF 2.0 và khung COBIT 2019
5	Soạn thảo khung BIA, BCP, DRP và CIRT Plan dựa trên các chức năng nghiệp vụ và chỉ số RTO/RPO của SmartEMS (Phần 4)	Xây dựng khung phục hồi và ứng phó sự cố đầy đủ theo thông lệ quản trị rủi ro doanh nghiệp	Claude, DeepSeek	Đáng tin về cấu trúc và nội dung khung; các mốc RTO/RPO cụ thể là ước lượng ban đầu	Nhóm/bản thân đối chiếu với đặc thù chức năng thực tế của SmartEMS (đăng nhập, chấm công, lương...) để điều chỉnh số liệu

5.2. Nhận định chung về giới hạn của AI trong dự án

Điểm mạnh khi sử dụng AI:

- Tăng tốc độ nghiên cứu và tổng hợp các tiêu chuẩn quốc tế (NIST, ISO/IEC, COBIT).
- Hỗ trợ xây dựng khung phân tích RMF có tính logic, tránh liệt kê lỗi kỹ thuật rời rạc.
- Chuẩn hóa văn phong trình bày và gợi ý cấu trúc bảng đánh giá rủi ro, ma trận Risk Level.

Điểm hạn chế / rủi ro khi sử dụng AI:

- AI không tự kiểm thử (pentest) trực tiếp trên hệ thống SmartEMS, nên các lỗ hổng ban đầu mang tính suy luận dựa trên mô tả kiến trúc, cần được đối chiếu lại với mã nguồn thật trước khi kết luận.
- Các con số định lượng (Likelihood, Impact, chi phí ước tính, RTO/RPO) do AI đề xuất chỉ mang tính tham khảo ban đầu, chưa phản ánh đầy đủ bối cảnh vận hành thực tế của doanh nghiệp mô phỏng.
- AI có thể ánh xạ chưa chính xác tuyệt đối với phiên bản mới nhất của một số tiêu chuẩn nếu không được kiểm tra chéo, do đó cần xác minh lại với tài liệu gốc trước khi trích dẫn chính thức.

Nguyên tắc đặt ra khi sử dụng AI trong quá trình thực hiện báo cáo:

- Không sao chép trực tiếp kết quả AI đưa ra mà không kiểm chứng lại.
- AI chỉ đóng vai trò hỗ trợ ở giai đoạn nháp ban đầu (cấu trúc, gợi ý, chuẩn hóa văn phong); nội dung và số liệu cuối cùng do người thực hiện quyết định.
- Luôn đối chiếu tối thiểu với một nguồn chuẩn quốc tế (NIST, ISO/IEC, OWASP...) trước khi đưa kết luận vào báo cáo chính thức.

Nhìn chung, AI đóng vai trò là công cụ hỗ trợ nghiên cứu và trình bày, giúp tiết kiệm thời gian hệ thống hóa quy trình đánh giá rủi ro, nhưng không thay thế được việc kiểm chứng thực tế và quyết định chuyên môn của người thực hiện báo cáo.

6. TÀI LIỆU THAM KHẢO (REFERENCES)

- NIST SP 800-37 Rev. 2 – Risk Management Framework for Information Systems and Organizations.
<https://csrc.nist.gov/pubs/sp/800/37/r2/final>

- NIST SP 800-30 Rev. 1 – Guide for Conducting Risk Assessments.
<https://csrc.nist.gov/pubs/sp/800/30/r1/final>
- ISO/IEC 27005:2022 – Information security, cybersecurity and privacy protection — Guidance on managing information security risks.
<https://www.iso.org/standard/80585.html>
- ISO/IEC 27001:2022 – Information security management systems — Requirements. <https://www.iso.org/standard/27001>
- NIST Cybersecurity Framework (CSF) 2.0.
<https://www.nist.gov/cyberframework>
- COBIT 2019 Framework – ISACA. <https://www.isaca.org/resources/cobit>
- OWASP Top 10:2021 – A01 Broken Access Control.
https://owasp.org/Top10/A01_2021-Broken_Access_Control/
- OWASP Top 10:2021 – A02 Cryptographic Failures.
https://owasp.org/Top10/A02_2021-Cryptographic_Failures/
- OWASP Password Storage Cheat Sheet.
https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html
- CWE-284: Improper Access Control.
<https://cwe.mitre.org/data/definitions/284.html>
- CWE-916: Use of Password Hash With Insufficient Computational Effort.
<https://cwe.mitre.org/data/definitions/916.html>
- CWE-362: Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition').
<https://cwe.mitre.org/data/definitions/362.html>
- CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). <https://cwe.mitre.org/data/definitions/22.html>
- Managing_Risk_in_Information_Systems.pdf